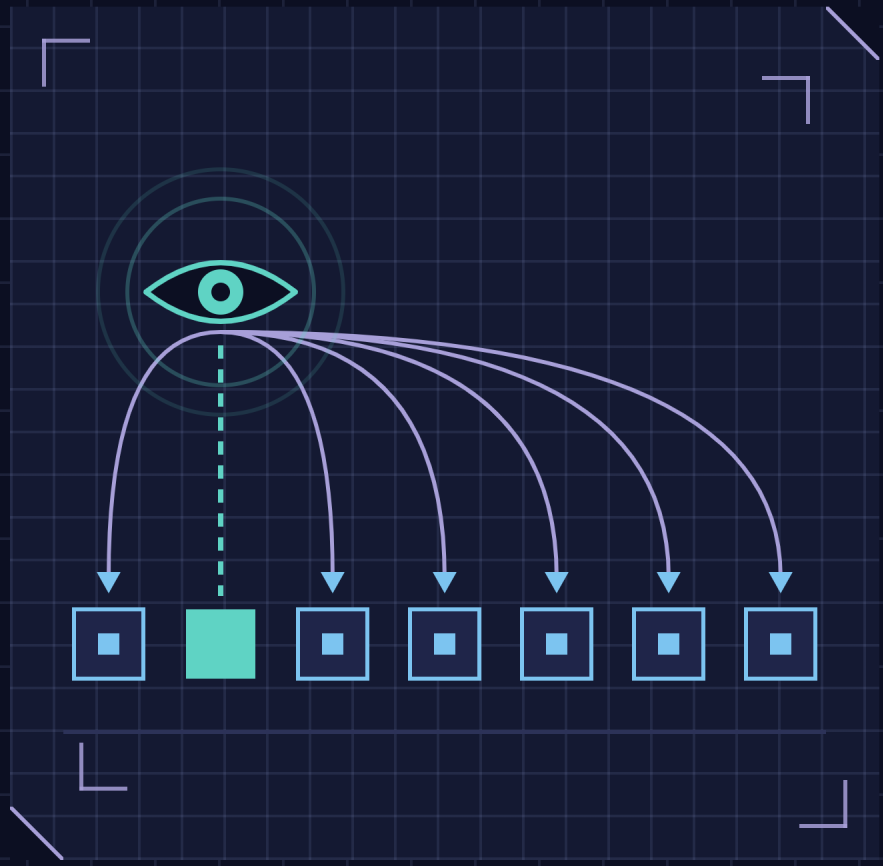
Розвідка кіберзагроз у складчину

Навіщо Україні спільний ISAC для критичної інфраструктури — і як нейтральна сторона робить обмін даними про кіберзагрози безпечним, швидким і якісним



ВСТУП

Спитайте себе...



Кобзар і зацікавлені споживачі інформації

- Про атаку на сусідню організацію ви дізнаєтеся з новин?
- Попередження надходять пізно або надто загальні, щоб діяти?
- Ваша команда мовчить про інциденти, бо боїться наслідків?
- Платите за розвідку, а релевантного для вашої галузі мало?
- Наймати власних аналітиків розвідки — дорого й довго?
- Хочете бачити загрози галузі мовою рішень, а не індикаторів?

Відповідь — довірене коло: ISAC

I

Проблема

Атакують галузь, а захищається кожен сам

ТЕЛЕКОМ · ГРУДЕНЬ 2023

Найбільший оператор — без зв’язку

~24 млн
абонентів без зв’язку

3,6 млрд ₴
коштував безкоштовний січень для абонентів

- 12 грудня 2023 року атака на ядро мережі: мобільний інтернет повертався до 58 годин.
- Перші спроби проникнення — ще в березні 2023 року, за даними СБУ; атаку приписують групі Sandworm.
- Знищено близько 40 % інфраструктури, загальні втрати оцінювали до 5 млрд ₴.

Публічно: «дані абонентів не витекли». Технічних деталей, корисних іншим операторам, — обмаль.

Джерела: DOU: Якою була атака на «Київстар» · Українська правда: проникли ще навесні — СБУ

Місяць без державних реєстрів

≈1 місяць
до відновлення всіх реєстрів Мін’юсту

11 днів
нотаріуси без ключових реєстрів

- 19 грудня 2024 року атакували інфраструктуру HAIC — оператора реєстрів Мін’юсту.
- Зупинилися послуги в «Дії»: акти цивільного стану, ЄДР, послуги для ФОП.
- Відповідальність узяло угруповання XakNet Team; його заяви про знищені дані не підтверджено.

Публічно: «дані збережено, витоку немає». Що сталося й чого навчитися іншим — невідомо.

Джерела: DOU: Мін’юст відновив роботу реєстрів · Факти: терміни відновлення реєстрів

РИТЕЙЛ · ЖОВТЕНЬ 2026

Атака з ШІ і вимога викупу

$400 тис.

вимога викупу з відліком у 2 години

7,9 млн

записів клієнтів — заява нападників, не підтверджена

- 5 жовтня 2026 року нападники зламали частину сервісів АТБ і вивісили вимогу викупу на сайті.
- За заявою компанії, ШІ використовували майже на кожному етапі: від розвідки до обходу захисту.
- Остаточні висновки компанія обіцяє після повного технічного розслідування.

Публічно: «критичних наслідків вдалося уникнути», значного витоку не підтверджено. Чому вірити — клієнти й ринок вирішують самі.

Джерела: Forbes Україна · ТСН: заява АТБ

ТРИ ІНЦИДЕНТИ · ОЦІНКА АВТОРА

Уроки є, а обміну немає

СПІЛЬНЕ В ТРЬОХ КЕЙСАХ

- **Мільярди гривень і тижні простою**
- **Заспокійливі заяви без пояснень**
- **Уроки не дійшли до інших**

ЧОМУ ІНФОРМАЦІЯ НЕ ДОХОДИТЬ

Страх

Репутація, юристи, перевірки: простіше промовчати.

Недовіра

Чи не дійде моє до конкурента чи в новини?

Повільність

Кожне повідомлення погоджують — воно застаріває.

Шум

Загальні бюлетені: незрозуміло, що стосується вас.

Кожен інцидент — урок, за який уже заплачено. Без обміну його оплачує кожен наступний.

ГОЛОВНА ДУМКА

Довіру між учасниками будує нейтральна сторона

ISAC знеособлює дані про інциденти, суворо дотримується TLP і відповідає перед учасниками. Тому ділитися стає безпечно — навіть із тими, кого не знаєш особисто.

II

Довірене коло

Що таке ISAC, хто в ньому і чому обмін там безпечний, швидкий і якісний

«

Центри обміну та аналізу інформації (ISAC) допомагають власникам і операторам критичної інфраструктури захищати свої об’єкти, персонал і клієнтів від кібер- і фізичних загроз та інших небезпек. ISAC збирають, аналізують і поширюють серед членів дієву інформацію про загрози й дають їм інструменти, щоб знижувати ризики та підвищувати стійкість.

US National Council of ISACs

About ISACs · переклад автора

НЕЙТРАЛЬНИЙ ЦЕНТР

Хто в колі і хто в центрі



Нейтральний оператор — центр довіри
Через нього йдуть усі повідомлення; він не конкурує з жодним учасником.

Учасники
Діляться через оператора за спільними правилами — не знаючи, хто саме повідомив.

Партнери — за угодами
CERT, постачальники розвідки, ISAC інших країн: обмін в обидва боки, без сирих даних.

Регулятори — поза колом
Лише знеособлена статистика й тренди.

ЯК ЦЕ ПРАЦЮЄ

Від сигналу одного — до захисту всіх

01 Збір

Учасники передають сигнали через захищену платформу — вручну або машина-машина.

02 Аналіз

Аналітики оператора перевіряють сигнали й додають контекст з інших джерел.

03 Дія

Попередження, брифінги для керівництва й IOC повертаються до всіх учасників.

↻ Відгуки учасників задають пріоритети наступного циклу.

Урок, який одна організація засвоїла дорогою ціною, стає захистом для всієї спільноти.

Поодинці видно лише частину загрози, разом — усю картину. За CI-ISAC, Prospectus (червень 2025)

УМОВНИЙ ПРИКЛАД

Як виглядає попередження ISAC

TLP:AMBER **Фішинг від імені постачальника ПЗ**

Що сталося	Листи «про оновлення ліцензії» з посиланням на підроблений портал; крадуть облікові дані VPN.
Кого стосується	Енергетика й телеком: за 48 годин повідомили 3 учасники, джерела знеособлено.
Індикатори	Домени й хеші — машиночитно в платформі; техніка MITRE ATT&CK T1566.002.
Що зробити	Заблокувати індикатори, перевірити журнали VPN за 14 днів, попередити бухгалтерію.

> **Одна сторінка — і команда знає, що робити сьогодні.**

TLP:AMBER — лише у своїй організації (і її клієнтам), тим, кому потрібно знати.

Умовний приклад; позначки — за FIRST TLP 2.0

МОДЕЛЬ CI-ISAC

Один ISAC, галузеві робочі групи



Галузеві групи · перелік відкритий · у США позагалузеві спільноти обміну називають ISAO

Для всіх

Розвідка, попередження й брифінги — незалежно від галузі: атаки через постачальників перетинають галузі.

У групах

Галузеві пріоритети, специфічні загрози й технології — наприклад, АСУ ТП в енергетиці.

ВІДПОВІДЬ НА ЧОТИРИ БАР'ЄРИ

Безпечно, швидко, якісно

УМОВА 1

Безпечно

- Знеособлення ще до аналізу; можна анонімно
- Межі поширення за TLP
- Оператор підзвітний учасникам

УМОВА 2

Швидко

- Наперед погоджено, що передавати одразу
- Решта — за процедурою зі строками
- Машиночитно; канал зв'язку в кризу

УМОВА 3

Якісно

- Перевірка: без хибного й застарілого
- Контекст: хто, як, навіщо
- Пріоритети за питаннями учасників

Ніколи не передаємо: персональні дані, внутрішні IP й назви систем, деталі захисту.

Джерела: CI-ISAC, Information Sharing Guidelines · ISAC як канал обміну в кризу — ENISA ISAC in a Box

III

Що отримують учасники

Продукти, користь для організації — і досвід Австралії

ПРОДУКТИ

Що отримує організація

Потоки індикаторів

Машиночитні IOC і TTP — для SIEM, EDR чи фаєрвола.

Попередження про кампанії

Що атакує зараз, кого саме і як захиститися.

Стратегічні брифінги

Регулярно для керівництва: тенденції й загрози галузі.

Аналітик на запит

Допомога з розслідуванням чи пошуком загроз — коли власних рук бракує.

Приклад набору послуг: CI-ISAC, Services

ЦІННІСТЬ

Менше ризику, менше витрат, сильніша галузь

Менше ризику

- Дізнаєтесь про атаку на галузь раніше, ніж вона дійде до вас
- Ресурси — на ризики, що справді загрожують
- Опора й зв’язок під час кризи

Менше витрат

- Розвідка в рази дешевша за власну команду
- Зекономлені години команди
- Документоване управління ризиками — аргумент для страховика

Сильніша галузь

- Зрілі допомагають менш зрілим
- Захищений спільний ланцюг постачання
- Власна спроможність, незалежна від вендорів

Ефект мережі: кожен новий учасник робить розвідку ціннішою для всіх.

Меседжі за CI-ISAC, Membership Benefits

ЕКОНОМІКА · ОЦІНКА АВТОРА

Сам чи разом: скільки коштує розвідка

СВОЯ КОМАНДА РОЗВІДКИ

$100–170 тис.

на рік — мінімум для однієї організації

- 2 аналітики: ≈ $70–110 тис.
- Комерційне джерело: від $30–60 тис.
- Пошук людей і 1–2 роки на розбудову

СПІЛЬНИЙ ISAC, 20 УЧАСНИКІВ

≈ $20–25 тис.

на рік — частка кожного учасника

- Команда оператора з 4–5 аналітиків
- Кілька комерційних джерел у складчину
- Сигнали 20 організацій, а не однієї
- Школа кадрів: навчання й наставництво

Оцінка автора · зарплати — DOU: зарплати Security, літо 2026 · ціни джерел — огляд цін на розвідку (UnderDefense, за даними Vendr)

ЦЕ ВЖЕ ПРАЦЮЄ

Австралія: CI-ISAC за три роки

150+
організацій-учасників

11
секторів КІ — усі в Австралії

700+
розвідувальних попереджень

3 роки
щоб зібрати цю спільноту

- Неприбуткова, керується учасниками: усі доходи — у сервіси
- Найбільшою користю учасники називають зекономлені години
- Серед учасників — місцеві ради, енергетики, IT-постачальники, університети

Джерела: CI-ISAC, Prospectus (червень 2025) · CI-ISAC, Membership

IV

Сумніви

Що зазвичай заперечують — і що на це відповісти

СУМНІВ 1

«Але в нас уже є CERT»

	Державний CERT	ISAC
Хто створює	Держава	Самі учасники
Головне завдання	Реагування й координація на національному рівні	Обмін і аналіз між колегами
Напрям обміну	Вертикально: повідомлення про інциденти	Горизонтально: між рівними
Що передають	Те, про що треба повідомити	Ще й ранні ознаки, про які повідомляти не треба
Фокус	Уся країна	Питання й пріоритети учасників

ISAC часто діляться дієвою інформацією швидше за державних партнерів — National Council of ISACs

«Великі гравці захоплять ISAC»

Один учасник – один голос

Вага в рішеннях не залежить від розміру внеску.

Платять по-різному, отримують однаково

Внесок залежить від розміру, а ядро розвідки — те саме для всіх, як у CI-ISAC.

Обмеження місць у правлінні

Не більше одного місця від організації й квота для кожної галузі.

Незалежний оператор

Виконавчу команду наймають, а не делегують найбільші учасники.

Ротація

Голови робочих груп і правління змінюються за графіком.

Прозорість

Статут і правила опубліковані; щорічний звіт для всіх учасників.

Пропоновані практики врядування; внески й однакові базові послуги — CI-ISAC, Membership

СУМНІВ 3

«А що скажуть юристи?»

Лише технічні дані

Індикатори й техніки, без персональних даних.

Угода учасника

Конфіденційність, TLP, обмеження відповідальності.

Без цін і ринків

Немає комерційної інформації — немає й антимонопольних питань.

Юристи з першого дня

Шаблони угод і позиція щодо законодавства.

ЯК У США

Закон CISA 2015 захищає від відповідальності за обмін; антимонопольні органи: належно організований обмін «не має викликати питань».

В УКРАЇНІ

Закон декларує обмін інформацією про загрози, але не регулює його між компаніями — тож правила фіксуємо в угоді.

Джерела: CISA 2015 · DOJ і FTC, 2014 · Закон № 2163-VIII

СУМНІВ 4

«У нас уже є чат у Signal»

	Чат у месенджері	ISAC
Хто всередині	Невідомо: хтось додав, хтось переслав	Перевірені учасники за угодою
Захист	Особисті телефони й акаунти	Захищена платформа й TLP
Якість	Пересилки без перевірки й контексту	Перевірка, контекст, пріоритети
Пам’ять	Тоне в стрічці за день	База й машиночитні індикатори
Відповідальність	Нічия	Оператор підзвітний учасникам

Ризики неформального обміну — CI-ISAC, Prospectus (червень 2025)

СУМНІВ 5

«А якщо зламають сам ISAC?»

Перевірка учасників

Вступ за рекомендацією; перевірка організації й контактних осіб.

Мінімум даних

Лише знеособлене; без сирих журналів; строк зберігання.

Розмежування доступу

Ролі, TLP, сильна автентифікація, журналювання дій.

План на компрометацію

Відкликання доступу, сповіщення учасників, перевірка.

ISAC — ціль для нападників, тож його захищають як критичну систему з першого дня.

СУМНІВ 6

«А що з цього піде державі?»

Обов’язкові повідомлення – як і раніше

ISAC не скасовує обов’язків перед регуляторами й CERT.

Державі – лише знеособлене

За угодою з CERT і лише те, що погодили учасники.

Запити – лише за законом

Дані конкретного учасника — тільки за законною процедурою.

Правила знають усі

Політика передачі даних — частина угоди учасника.

Довіра тримається на передбачуваності: учасник наперед знає, що й кому може піти.

V

Як почати

Від ініціативної групи до робочого центру — і скільки це коштує

ДОРОЖНЯ КАРТА

Чотири фази до зрілого ISAC

01
Побудова
- Ініціативна група
- Статут і правила обміну, TLP
- Оператор і платформа

02
Робота
- Регулярні зустрічі й обмін
- Перші продукти — пілот
- Довіра між учасниками

03
Оцінка
- Час від сигналу до попередження
- Частка дієвих попереджень
- Скільки учасників діляться

04
Розвиток
- Нові учасники й галузеві групи
- Конвеєр розвідки й автодоставка
- Зв’язки з CERT та іншими ISAC

Модель, керована учасниками: ISAC починає один з учасників і росте знизу вгору.

До наступної фази — коли виконано базові вимоги попередньої · ENISA ISAC in a Box · The member-driven model

НАСТУПНИЙ ЕТАП

Згодом: конвеєр розвідки для всіх

На вході: сигнали учасників, CERT, комерційні й відкриті джерела

01
Відбір
За загальними розвідувальними вимогами учасників

02
Перевірка
Правдивість, якість, несуперечність

03
Кореляція
Зв’язки між сигналами різних учасників

04
Пакування
У стандартний формат STIX

05
Доставка
Через TAXII — автоматично в SIEM, EDR, фаєрвол

STIX і TAXII — простими словами

STIX — опис загрози спільною мовою засобів захисту. TAXII — сервер і протокол, що віддає ці описи пачками (колекціями) за підпискою.

Людина в контурі

Спірне й важливе вирішують аналітики, рутину — автоматика.

Що вирішує успіх ISAC

Довіра понад усе

Прозорість і передбачуваність; довіру будують свідомо.

Статут від учасників

Самі учасники його приймають і регулярно переглядають.

Почати з малого

Робочий ISAC будують роками — терпіння й послідовність.

Берегти час учасників

Секретаріат бере на себе зустрічі, платформу й матеріали.

Живе спілкування

Неформальні зустрічі будують довіру не гірше за правила.

Зручна захищена платформа

Інакше онлайн-обмін просто не приживеться.

Джерело: ENISA ISAC in a Box, Recommendations

УЧАСТЬ

Що вимагається і що ви отримаєте

ЩО ВИМАГАЄТЬСЯ

Від учасника

- Контактна особа й аналітик: кілька годин на тиждень
- Ділитися хоча б висновками з власних інцидентів
- Відгуки на попередження: корисне, хибне, бачили в себе
- Хто лише читає — бачить свій внесок у щорічному звіті

ПЕРШІ 90 ДНІВ

Що отримуєте

- Доступ до платформи й щоденних попереджень
- Індикатори у форматі для імпорту в SIEM
- Перший галузевий брифінг для керівництва
- Місце в галузевій робочій групі

Беруть більше ті, хто більше дає: обмін — це взаємність.

Як платять за ISAC в Австралії



РІЧНИЙ ДОХІД, AUD	ВНЕСОК НА РІК, AUD
> 5 млрд (> $3,5 млрд)	**45 000** (≈ $31 500)
1–5 млрд (≈ $0,7–3,5 млрд)	**35 000** (≈ $24 500)
0,5–1 млрд (≈ $350–700 млн)	**27 500** (≈ $19 250)
250–500 млн (≈ $175–350 млн)	**20 000** (≈ $14 000)
100–250 млн (≈ $70–175 млн)	**15 000** (≈ $10 500)
50–100 млн (≈ $35–70 млн)	**10 000** (≈ $7 000)
10–50 млн (≈ $7–35 млн)	**5 000** (≈ $3 500)
< 10 млн (< $7 млн)	**1 500** (≈ $1 050)

$1–31 тис.
на рік з однієї організації

Ядро – однакове
Ті самі базові послуги для всіх.

Знижки 15-30 %
Неприбутковим і держмедзакладам.

Це приклад Австралії: в Україні модель і внески, найімовірніше, будуть іншими.

Перехідні внески CI-ISAC на 2026 рік · CI-ISAC, Membership · у дужках — орієнтовно в доларах США за курсом ≈ 0,70 $ за 1 AUD (жовтень 2026)

УРОК США

Не будувати ISAC на чужому бюджеті

18 574
учасників — вересень 2025

→

5 618
учасників — червень 2026

- MS-ISAC роками жив на федеральні кошти США.
- 30 вересня 2025 року фінансування припинили — довелося запроваджувати внески.
- За дев’ять місяців — мінус ~70 % учасників.

> **Внески учасників — з першого дня. Гранти — доповнення, а не основа.**

Джерела: Cybersecurity Dive · StateTech

Дякую

Питання й обговорення

Іван Гокін LinkedIn · GitHub

Додатки

Деталі для аналітиків і відповіді на рідші запитання

ДОДАТОК · ДЛЯ АНАЛІТИКІВ

Технічна кухня обміну

Позначки

TLP 2.0 — кому можна; PAP — що можна робити з даними.

Якість

Рівень впевненості, надійність джерела, строк життя індикатора.

Зворотний зв’язок

Хибне спрацювання чи «бачили в себе» — оцінка індикатора.

Спільнота аналітиків

Закритий канал, спільні розбори, навчання й наставництво.

Формати й доставка — на слайді про конвеєр · стандарти: OASIS STIX/TAXII, FIRST TLP 2.0, MISP, MITRE ATT&CK

«Залізний» трикутник кібербезпеки



«Це ж ще одна асоціація»

	ISAC	Галузева асоціація
Цільова аудиторія	Фахівці з кібербезпеки, CISO	Галузеві фахівці, вище керівництво
Зона відповідальності	Обмін та аналіз інформації про кіберзагрози	Розвиток галузі
Межі	Усі галузі критичної інфраструктури	Одна галузь

ЩО ПОЧИТАТИ

Джерела

ХТО	ЩО ПОЧИТАТИ
CI-ISAC	Info Sharing Guidelines · Prospectus · Membership
ENISA	ISAC in a Box · Recommendations
США · ISAC	National Council of ISACs · ISAO FAQ · MS-ISAC
США · право	CISA 2015 · DOJ і FTC про антимонопольні ризики
Економіка	DOU: зарплати Security · ціни на розвідку
Стандарти	OASIS STIX і TAXII · FIRST TLP 2.0
Кейси	«Київстар» · реєстри Мін’юсту · АТБ
Україна	Закон про основні засади кібербезпеки · НІСД про ДПП